
Stalham Infants School**Audit Date: 04/03/20****Report: Year 2 visit 2****DPE: Stuart Lee****School member: Glenn Russell**

1. Visit details

Glenn has taken on the headship from Sarah and will combine this with the headship at Stalham Junior School. Both schools are now part of the Trust with Stalham Infants purchasing the DPE service and the Junior school coming under the Trust for DPO services. At the time of the visit negotiations between DPE and the Trust were ongoing regarding purchasing a Trust package. Part of the visit was to brief Glenn on the service and how DPE supports schools with their GDPR project.

There is a possibility that the school will operate from one site, whilst still having both sites available and will also keep their independence. They will continue to be run as 2 separate schools.

Min follow up actions:

- SL to send Glenn any paperwork documentation from the site move workshop being held on 13 March. Glenn also has the option to attend.
- SL to send link to IRMS data retention toolkit (section 3.1 below)
- School to liaise with SL regarding a mop up walk at the vacated site to assess privacy risk if the school site move should materialise;
- SL to contact Kalina (DPE) and arrange a time to go over the DPE website with Glenn. Glenn is also to be set up on the DPE website;
- Admin (Heather) to liaise with Glenn to arrange a walk at the junior school (subject to the Trust buying in to the service) – preferably afterschool;
- Discussed work away from school; Trust have practice documents and whole trust policies. Glenn to check current Trust practice documents for working away from school, especially as the Trust has moved to cloud solutions;
- If operating as 2 schools within the 1 site SL to follow up with DPE in relation to 1 log in for headteachers/school managers;
- Glenn to follow up with the Trust if the current Infant school server is being decommissioned; how is data being cleansed; archiving; removing sensitive data etc.

2. Audit walk findings and follow up actions

The DPE best practice guide was distributed and prior to the walk best practice around physical security was discussed with Glenn. It was also suggested that an afterschool walk be completed. Afterschool walks are useful in identifying risks that would not necessarily be identified with walks completed during the day.

Physical folders

- 1 x folder with outdated assessment data. **Advisory:** School to use as an opportunity to complete a data cleanse and ensure data in folders is up to date and accurate.

Medical data

- School to review how data is displayed. Medical/care plans on display; back of cupboard; storeroom and nursery. **Advisory:** Is this the best place to store this information? Can folder systems be used? Can the school utilise its MIS and just keep one central folder (front office) and minimise data that is used by the classroom practitioners?

Laptop security

- 1 x laptops unlocked. **Action point:** Reminder to staff to lock laptops when away from work area (short cut:  windows + L).

Mobile devices

- Mobile devices have passcodes. **Action point:** School to check what photos are on individual devices. Do routines include wiping data on a regular basis?

Pigeonholes

- 1 x hospital appointment letter observed that was outdated (previous years). **Action point:** School to ascertain if pigeonholes are still needed; reminder to staff to regularly check and not to store sensitive data in pigeonholes.

3. Compliance actions that should now be completed

Initial documents:

- Privacy Notice
- GDPR Policy
- Data Breach Procedure
- SAR procedure
- Photo and Video consent, guidelines and records

Ideally you would also have: Work away from school, clear desk and screen, information classification and record management policy/paperwork. Schools have either adopted the DPE models or incorporated some of this within their staff handbook, for example, work away from school.

The following should also be completed:

- There should be no named person on any of the above documents. If there is a named person i.e. Stuart Lee, the name needs replacing with: Data Protection Education Ltd;
- The Privacy Notice should have an appendix with your third-party suppliers listed. If using GDPRiS this should also be kept updated. You should also make sure suppliers are GDPR compliant;
- The Privacy Notice, GDPR Policy and consent withdrawal form should be displayed on the school website;
- All staff should know what the data procedure is, and the document should be circulated to all staff;
- Key staff responding to SARs should have access to the SAR procedure and understand their responsibilities.

3.1. Data retention schedule:

By now you should be working through both physical and electronic data and have a good understanding of what data you hold and be documenting this. There are a number of documents available to support the process:

- Governor hub: annual review of school data and safe data destruction checklist
- IRMS toolkit: https://c.ymcdn.com/sites/irms.site-ym.com/resource/collection/8BCEF755-0353-4F66-9877-CCDA4BFEEAC4/2016_IRMS_Toolkit_for_Schools_v5_Master.pdf
- DfE toolkit
https://assets.publishing.service.gov.uk/government/uploads/system/uploads/attachment_data/file/747620/Data_Protection_Toolkit_for_Schools_OpenBeta.pdf (Annex 5,1)

3.2. Staff training

GDPR training should be completed and documented. If not already you should:

- Rollout training to key staff and then consider all staff completing the e-learning training;
- Add as part of the induction process for new staff;
- Use staff meetings/briefings to raise staff awareness.

3.3. Governance/Trustee check

It should form part of governance that GDPR is an item at trustee/governor meetings and to share reports with trustee/governors. Ideally the trustee/governor responsible for GDPR will have completed some form of GDPR training.

3.4. Make sure DPE is your registered DPO with the ICO

Not only do you need to be registered as a controller with the ICO, it is a requirement to register who your DPO is. The guide to complete this is available from the News section of the DPE website: <https://kb.dataprotection.education/news-top/news/83-best-practice-updates/110-make-sure-dpe-is-your-registered-dpo-with-the-ico> **If you are part of a Trust, this will be completed at Trust level.**

4. Freedom of Information and Publication Scheme (public authorities)

The DPE GDPR policy and FOI policy content refer to the organisation having a publication scheme - do you have one (LA maintained schools)? **The template for a model publication scheme can be obtained from:** <https://ico.org.uk/media/for-organisations/documents/1235/definition-document-schools-in-england.pdf> How to complete a publication scheme guide can be obtained from: <https://ico.org.uk/media/for-organisations/documents/1242/how-to-complete-template-guide-to-info-for-schools.pdf> Additional guidance can be obtained from the news section of the DPE website: <https://kb.dataprotection.education/news-top/news>

5. Technical measures

DPE recommends schools complete the Cyber essentials questionnaire available from: DPE>Resources> Information Technology Security: <https://kb.dataprotection.education/best-practice-library/documents/information-technology-security/7-crest-cyber-essentials-questionnaire>;

Check iPad/Tablet security. Are all laptops encrypted, does your end of day routines include housekeeping to remove data no longer needed and is equipment secured? Do staff still use unencrypted memory sticks? DPE recommends schools develop procedures to ensure iPads can be accounted for daily and data (i.e photos) can be cleared if lost or stolen ([Erase your device](#))

6. Next steps

Record of Processing (RoP) tool and data mapping

DPE have started to populate the Record of Processing (RoP) tool. Rather than each school complete individually, DPE will be populating as many processes as possible and then work with you to complete for your school. It is a requirement under article 30 of the GDPR and will form part of the basis for future remote sessions and visits.

6.1. Data Protection Impact Assessments (DPIA)

When processing high risk personal data and using new technologies (i.e. moving to a new technology for Safeguarding) a DPIA should be completed and the DPO consulted (Article 35.2). DPIAs offer a risk assessment template where concerns can be noted alongside mitigating actions to reduce the overall risks related to change of practice. It is good practice to complete a DPIA for any major project where the processing of personal data is required. DPE will be providing more guidance, training and include risk management within the RoP tool. Always contact DPE in the first instance.